



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Gardyn IoT Hub Cloud API Hard-Coded Credential Exposure

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-07-05
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | Gardyn IoT Hub Cloud API Hard-Coded Credential Exposure - CVE / Vulnerability Threat Intelligence Report

Published: 2026-07-05 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
 - 9.1. Detection Logic Summary
 - 9.2. Sigma / Detection Rule
 - 9.3. Hunt Query
10. Threat Hunting
 - 10.1. Hunt Hypothesis
 - 10.2. Hunt Query
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

Gardyn IoT Hub Cloud API Hard-Coded Credential Exposure

1. Executive Summary

CISA published ICSA-26-183-03 for Gardyn IoT Hub on 2026-07-02, covering three Cloud API vulnerabilities affecting versions before 2.12.2026. The most urgent issue is CVE-2026-13768, a CVSS 3.1 10.0 hard-coded credential exposure that can enable unauthenticated network access to highly privileged Azure IoT Hub administration capability. Public secondary references describe the exposed credential as an `iothubowner` administrative credential able to retrieve connection information for Gardyn Home Kit and Studio devices.

Defenders should prioritize this item because the vulnerable surface is a cloud-connected IoT control plane rather than a single local appliance. A compromise path that exposes fleet connection metadata can turn consumer or small-business smart-growing equipment into a broader privacy, device-control, or pivot risk, especially where IoT devices share networks with enterprise assets.

Immediate priorities are to confirm whether Gardyn IoT Hub deployments have been updated to the fixed infrastructure, rotate any exposed administrative/shared access credentials, review Azure IoT Hub/device-registry audit evidence, and segment IoT devices away from corporate user, server, and management networks.

2. Vulnerability Metadata

Field	Value
Primary CVE	CVE-2026-13768
Additional CVEs	CVE-2026-55726; CVE-2026-54477
Product / Component	Gardyn IoT Hub Cloud API
Weakness	Hard-coded credentials / exposed privileged cloud API access; related cloud API confidentiality and integrity issues
Severity	Critical; CVE-2026-13768 CVSS:3.1 10.0 vector AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:L
Affected Versions	Cloud API versions earlier than 2.12.2026
Fixed Versions / Remediation	Gardyn states deployed IoT Hub infrastructure has been updated; rotate exposed administrative credentials and validate tenant/device registry access
Disclosure Date	2026-07-02 CISA ICS advisory
Exploitation Status	Public technical references and PoC-style discussion observed; no confirmed exploitation in the reviewed sources

3. Source Review & Confidence

Source	Contribution	Confidence
CISA ICSA-26-183-03	Canonical affected product, version, CVSS vectors, mitigation language, and industrial-control-system network-exposure guidance	High

OpenCVE / CVE aggregation for CVE-2026-13768	Confirms CVE naming, product, and vendor-solution summary	Medium
Strix CVE analysis and public GitHub proof-of-concept references	Adds defender context about privileged `iothubowner` credential impact and likely abuse path	Medium

Confidence is high that CVE-2026-13768 is a critical cloud API exposure affecting Gardyn IoT Hub versions before 2.12.2026 because CISA published the advisory and CVSS vectors. Confidence is medium for public exploitation likelihood: sources discuss abuse mechanics and public research artifacts, but no reviewed source confirmed real-world exploitation.

4. Vulnerability Details

CVE-2026-13768 is the priority defect in a three-CVE Gardyn IoT Hub advisory. The vulnerability is modeled as use of hard-coded credentials in the Cloud API. CISA reports a network-reachable, no-authentication, no-user-interaction vector with changed scope and high confidentiality and integrity impact. Public analysis indicates the credential can access Azure IoT Hub Registry Manager functionality and retrieve connection details for devices in the Gardyn ecosystem.

The additional CVEs increase the defensive concern because they indicate the advisory is not a single isolated bug. CVE-2026-55726 is scored with network access, no privileges, no user interaction, and confidentiality impact. CVE-2026-54477 requires user interaction and carries lower confidentiality/integrity impact. Defenders should still treat the advisory as a control-plane hardening event: patch status, credential rotation, API audit review, and network segmentation should be completed as a bundle.

5. Attack Scenarios

- ****Cloud control-plane credential abuse:**** An unauthenticated actor obtains or reuses the hard-coded credential and queries device-registry data to enumerate Gardyn devices, connection strings, or cloud-to-device control metadata.
- ****IoT-to-enterprise pivot preparation:**** Device identity or connection metadata is used to profile small-office networks where Gardyn devices coexist with corporate laptops, guest Wi-Fi, or building-management devices.
- ****Privacy or nuisance impact:**** Attackers use cloud API access to infer user/device presence, device ownership, or operational patterns even without confirmed destructive capability.

6. Threat Landscape & Exploitation Status

The reviewed sources do not confirm active exploitation. However, the advisory has a critical CVSS score, public CVE indexing, and public research/PoC references. That combination is enough to justify rapid validation. IoT control-plane bugs often become durable exposure because devices and cloud integrations are not owned by the same team that manages enterprise endpoint patching.

Signal	Assessment	Defender Implication
CISA ICS advisory	Public, authoritative disclosure	Treat as operationally relevant even outside traditional ICS environments
CVSS 10.0 vector	Network reachable, unauthenticated, broad impact	Prioritize above routine IoT vulnerabilities
Cloud API / Azure IoT Hub context	Credential/API audit may be more useful than endpoint telemetry alone	Review cloud logs, device registry changes, and unusual API calls
No confirmed exploitation	Risk is exposure-driven rather than incident-confirmed	Validate and monitor without claiming compromise

7. Affected Products and Exposure

Exposure Pattern	Why It Matters
------------------	----------------

Gardyn Cloud API before 2.12.2026	Primary affected component; fixed via deployed infrastructure update per CISA/vendor statement
Small-office IoT devices on enterprise Wi-Fi	Consumer IoT can sit near corporate endpoints and become a reconnaissance or pivot foothold
Shared cloud/device credentials	Credential rotation is required; patching alone may not invalidate copied credentials
Segmented IoT VLAN with egress controls	Reduces enterprise blast radius even if device-cloud credentials are abused

8. Mitigation and Workarounds

1. Confirm Gardyn IoT Hub services are on fixed infrastructure and document vendor response.
2. Rotate all Gardyn/Azure IoT Hub administrative or shared-access credentials that could have been exposed, especially `iothubowner`-equivalent keys.
3. Review Azure IoT Hub, device-registry, and API audit logs for unusual enumeration, registry reads, device twin changes, cloud-to-device messaging, or unexpected source networks.
4. Place Gardyn and similar IoT devices on segmented networks with restricted east-west access to corporate endpoints and management planes.
5. Block direct inbound access to control-system or IoT management interfaces from the internet, consistent with CISA ICS guidance.

9. Detection Engineering

9.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
Spike in IoT Hub registry reads or connection-string retrieval	Azure Activity / IoT Hub diagnostic logs	Identify credential-driven enumeration
API calls using high-privilege shared access policy from unfamiliar IPs	Cloud audit logs, proxy logs	Detect abuse of exposed administrative credential
IoT device network connections to unusual external endpoints	Firewall, DNS, DeviceNetworkEvents	Surface post-exposure staging or pivot behavior

9.2. Sigma / Detection Rule

```

title: Gardyn or Azure IoT Hub Administrative Credential Enumeration
id: 61e21c20-8f7c-45aa-8ef2-gardyn-iothub-enum
status: experimental
description: Detects unusual IoT Hub registry enumeration or connection string retrieval that may follow exposure of privileged IoT Hub credentials.
logsource:
  product: azure
  service: activitylogs
detection:
  selection_operation:
    OperationName|contains:
      - 'IoTHub'
      - 'Registry'
      - 'Device'

```

```

selection_action:
  OperationName|contains:
    - 'list'
    - 'read'
    - 'connection'
filter_known_admins:
  CallerIpAddress:
    - 'KNOWN_ADMIN_IP'
condition: selection_operation and selection_action and not filter_known_admins
fields:
  - TimeGenerated
  - Caller
  - CallerIpAddress
  - OperationName
  - ResourceGroup
  - ResourceId
level: high

```

9.3. Hunt Query

```

AzureActivity
| where TimeGenerated > ago(30d)
| where ResourceProviderValue has_any ('Microsoft.Devices', 'IotHub')
| where OperationNameValue has_any ('list', 'read', 'registry', 'device', 'connection')
| summarize Count=count(), FirstSeen=min(TimeGenerated), LastSeen=max(TimeGenerated),
Operations=make_set(OperationNameValue, 20) by Caller, CallerIpAddress, ResourceId
| where Count > 10 or CallerIpAddress !in ('KNOWN_ADMIN_IP')
| order by LastSeen desc

```

10. Threat Hunting

10.1. Hunt Hypothesis

A leaked or hard-coded IoT Hub administrative credential will be used from infrastructure that differs from normal vendor or administrator ranges and will create registry-read, device-enumeration, or unusual device-message patterns before any visible endpoint impact.

10.2. Hunt Query

```

DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemoteUrl has_any ('azure-devices.net', 'devices.net') or RemoteUrl has 'iothub'
| summarize Connections=count(), FirstSeen=min(Timestamp), LastSeen=max(Timestamp),
Devices=make_set(DeviceName, 50) by RemoteUrl, RemoteIP, InitiatingProcessAccountName
| where Connections > 25
| order by LastSeen desc

```

11. MITRE ATT&CK Mapping

Technique	Name	Evidence / Rationale
T1552	Unsecured Credentials	Hard-coded credential exposure is the core issue reported for CVE-2026-13768
T1580	Cloud Infrastructure Discovery	Registry/device enumeration can disclose cloud-connected device inventory
T1021	Remote Services	Abuse path is remote API/service access rather than local exploitation
T1046	Network Service Discovery	Follow-on profiling of IoT endpoints and cloud services is plausible after credential abuse

12. Validation / Lab Testing

No live exploitation or Gardyn tenant testing was performed. Validation completed for this report included source review of the CISA advisory, public CVE aggregation, public research references, CVSS vector review, and construction of cloud/API-centric detection logic. Operational users should validate the KQL field names against their Azure diagnostic-log schema before deployment.

13. Recommended Actions Summary

Priority	Owner	Action
Critical	Cloud / IoT owner	Confirm fixed Gardyn infrastructure and rotate all IoT Hub administrative/shared-access keys
High	Detection Engineering	Enable and review Azure IoT Hub diagnostic logging and deploy registry-enumeration detection
High	Network Engineering	Segment Gardyn/IoT devices and restrict east-west access to enterprise networks
Medium	Security Operations	Search 30 days of cloud, DNS, and firewall logs for unusual IoT Hub API access

14. References

- [1] CISA, "Gardyn IoT Hub," ICSA-26-183-03, 2026-07-02: <https://www.cisa.gov/news-events/ics-advisories/icsa-26-183-03>
- [2] OpenCVE, "CVE-2026-13768 - Gardyn IoT Hub Use of Hard-coded Credentials": <https://app.opencve.io/cve/CVE-2026-13768>
- [3] Strix CVE analysis, "CVE-2026-13768: Gardyn devices expose a privileged iothubowner...": <https://www.strix.ai/cve/CVE-2026-13768>
- [4] Public research reference, "CVE-2026-13768" proof-of-concept repository: <https://github.com/MichaelAdamGroberman/CVE-2026-13768>